



ZAP by Checkmarx Scanning Report

Site: <https://ismsponsor.azurewebsites.net>

Generated on Thu, 23 Apr 2026 19:13:43

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	2
Informational	5

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	3
Low	Exceeded High	https://ismsponsor.azurewebsites.net	Percentage of slow responses	79 %
Info	Informational	http://ismsponsor.azurewebsites.net	Percentage of responses with status code 3xx	100 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of responses with status code 2xx	71 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of responses with status code 3xx	1 %
Info	Exceeded Low	https://ismsponsor.azurewebsites.net	Percentage of responses with status code 4xx	28 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of endpoints with content type image/png	14 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of endpoints with content type text/css	14 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of endpoints with content type text/html	57 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of endpoints with method GET	85 %
Info	Informational	https://ismsponsor.azurewebsites.net	Percentage of endpoints with method POST	14 %
Info	Informational	https://ismsponsor.azurewebsites.net	Count of total endpoints	7

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	4

CSP: script-src unsafe-eval	Medium	4
CSP: script-src unsafe-inline	Medium	4
CSP: style-src unsafe-inline	Medium	4
Cookie with SameSite Attribute None	Low	4
Cookie without SameSite Attribute	Low	3
Authentication Request Identified	Informational	1
Re-examine Cache-control Directives	Informational	1
Session Management Response Identified	Informational	6
User Agent Fuzzer	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	2

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	

Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055
Medium	CSP: script-src unsafe-eval
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	Content-Security-Policy

Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-eval.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055
Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'

Other Info	script-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	script-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055
Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/

Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https;; connect-src 'self'; worker-src 'self';; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Other Info	style-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055
Low	Cookie with SameSite Attribute None

Description	A cookie has been set with its SameSite attribute set to "none", which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	ARRAffinitySameSite
Attack	
Evidence	Set-Cookie: ARRAffinitySameSite
Other Info	
URL	https://ismsponsor.azurewebsites.net/Settings/Account/GoogleLogin
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/GoogleLogin
Method	GET
Parameter	.AspNetCore.Correlation.NvqnSG9XxR1JGtT9yvvk7pt5bHj2m3B2wodted_Zn1U
Attack	
Evidence	Set-Cookie: .AspNetCore.Correlation.NvqnSG9XxR1JGtT9yvvk7pt5bHj2m3B2wodted_Zn1U
Other Info	
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	ARRAffinitySameSite
Attack	
Evidence	Set-Cookie: ARRAffinitySameSite
Other Info	
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	ARRAffinitySameSite
Attack	
Evidence	Set-Cookie: ARRAffinitySameSite
Other Info	
Instances	4
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low Cookie without SameSite Attribute

Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/

Method	GET
Parameter	ARRAffinity
Attack	
Evidence	Set-Cookie: ARRAffinity
Other Info	
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	ARRAffinity
Attack	
Evidence	Set-Cookie: ARRAffinity
Other Info	
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	ARRAffinity
Attack	
Evidence	Set-Cookie: ARRAffinity
Other Info	
Instances	3
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054
Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Username
Attack	
Evidence	Password userParam=Username userValue=ZAP
Other Info	passwordParam=Password referer=https://ismsponsor.azurewebsites.net/
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

CWE Id	
WASC Id	
Plugin Id	10111
Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	cache-control
Attack	
Evidence	no-cache,no-store
Other Info	
Instances	1
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015
Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	.AspNetCore.Session
Attack	
Evidence	.AspNetCore.Session cookie:.AspNetCore.Session
Other Info	cookie:ARRAffinity cookie:ARRAffinitySameSite cookie:.AspNetCore.Antiforgery.cdV5uW_Ejgc
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	.AspNetCore.Session
Attack	

Evidence	.AspNetCore.Session cookie:.AspNetCore.Session
Other Info	cookie:ARRAffinity cookie:ARRAffinitySameSite
URL	https://ismsponsor.azurewebsites.net/sitemap.xml
Node Name	https://ismsponsor.azurewebsites.net/sitemap.xml
Method	GET
Parameter	.AspNetCore.Session
Attack	
Evidence	.AspNetCore.Session cookie:.AspNetCore.Session
Other Info	cookie:ARRAffinity cookie:ARRAffinitySameSite
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	.AspNetCore.Antiforgery.cdV5uW_Ejgc
Attack	
Evidence	.AspNetCore.Antiforgery.cdV5uW_Ejgc
Other Info	cookie:.AspNetCore.Antiforgery.cdV5uW_Ejgc
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	.AspNetCore.Session
Attack	
Evidence	.AspNetCore.Session
Other Info	cookie:.AspNetCore.Session
URL	https://ismsponsor.azurewebsites.net/robots.txt
Node Name	https://ismsponsor.azurewebsites.net/robots.txt
Method	GET
Parameter	ARRAffinity
Attack	
Evidence	ARRAffinity
Other Info	cookie:ARRAffinity
Instances	6
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	https://ismsponsor.azurewebsites.net
Node Name	https://ismsponsor.azurewebsites.net
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	https://ismsponsor.azurewebsites.net/
Node Name	https://ismsponsor.azurewebsites.net/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	

WASC Id	
Plugin Id	10104
Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Password
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://ismsponsor.azurewebsites.net/Settings/Account/Login appears to include user input in: a(n) [input] tag [value] attribute The user input found was: Password=ZAP The user-controlled value was: zap
URL	https://ismsponsor.azurewebsites.net/Settings/Account/Login
Node Name	https://ismsponsor.azurewebsites.net/Settings/Account/Login () (Password,ReturnUrl,Username,__RequestVerificationToken)
Method	POST
Parameter	Username
Attack	
Evidence	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://ismsponsor.azurewebsites.net/Settings/Account/Login appears to include user input in: a(n) [input] tag [value] attribute The user input found was: Username=ZAP The user-controlled value was: zap
Instances	2
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

CWE Id	20
WASC Id	20
Plugin Id	10031

Sequence Details

With the associated active scan results.